metricstream

Preparing for HIPAA's 2025 Security Rule Updates

How Healthcare Risk Teams Can Stay Ahead of the Curve

Introduction



As the threat landscape intensifies, the healthcare sector has become one of the most targeted industries for cyberattacks. The reason is clear: healthcare data is immensely valuable, and cybersecurity practices have historically lagged behind other sectors. In April 2025 alone, healthcare data breaches, as reported by the HIPAA journal, increased 17.9% month over month, affecting approximately 10.26 million individuals. At the same time, healthcare organizations continue to invest only 4–7% of their IT budgets in cybersecurity, far below industries like finance, which allocate closer to 9.6%.

To address these gaps and evolving threats, the U.S. Department of Health and Human Services (HHS) issued a Notice of Proposed Rulemaking (NPRM) in December 2024 to modernize the HIPAA Security Rule. This proposed update—published in the Federal Register in January 2025—marks the most significant change to the regulation since 2005 and is intended to bring healthcare security into alignment with today's digital risks. Over 4,000 public comments poured in during the 60-day comment period, underscoring the urgency and industry-wide impact that these changes have brought.

Top Updates to Expect

The proposed changes to HIPAA's Security Rule are both comprehensive and transformative. While HIPAA has served the healthcare industry well since its enactment in 1996, it is long overdue for a refresh. Here are the most impactful updates:

1	Mandatory Multi-Factor Authentication (MFA)	The proposed rule mandates MFA across all access points to electronic Protected Health Information (ePHI). Users must authenticate using multiple credentials, such as passwords, biometric scans, or hardware tokens. This helps reduce the risk of unauthorized access, even if a password is stolen or compromised, thus heightening data security.
2	Required Data Encryption	While previously optional, encryption is now a requirement for ePHI—both in transit and at rest. This is a major shift for many providers and business associates, and it reflects the critical need to safeguard sensitive data as it moves across systems or resides on devices and servers.
3	Elimination of "Addressable" vs. "Required" Controls	Historically, HIPAA distinguished between "required" and "addressable" safeguards, allowing organizations some leeway in how they implemented certain controls. This flexibility, however, often led to inconsistency. Under the new rules, all safeguards are mandatory, promoting a more consistent security posture across the industry.

© 2025 Copyright MetricStream. All Rights Reserved.

4	**Asset Inventories and Network Mapping**	Organizations must maintain comprehensive inventories of their technology assets and detailed network maps. These tools ensure visibility into all systems that handle ePHI and help organizations monitor for vulnerabilities, unauthorized access, or unpatched legacy devices.
5	**Annual Security Audits**	Healthcare organizations will now be required to conduct and document annual audits of their administrative, technical, and physical security controls. This proactive approach moves organizations away from reactive compliance and toward a culture of continuous improvement and accountability.
6	**Vulnerability Scanning and Penetration Testing**	To better understand and mitigate potential weaknesses, entities must perform vulnerability scans at least twice a year and penetration tests annually. These measures will help uncover both known and unknown vulnerabilities, enabling timely mitigation before real-world attackers can exploit them.

Together, these updates signify a major regulatory shift—one that codifies modern cybersecurity best practices while eliminating ambiguity around compliance requirements.

How Healthcare Organizations Can Plan for the Proposed Changes

While the proposed rules are not yet finalized, waiting to act would not be advisable. Cybersecurity leaders in healthcare should begin preparing now by building a more integrated, proactive, and forward-looking approach to risk.

Educate and Engage Leadership

Regulatory change affects the entire organization—not just IT or compliance teams. Cybersecurity leaders must ensure that executives and board members understand what's coming and what's at stake. This includes the operational impact of non-compliance, the financial cost of a breach, and the reputational damage that tends to follow.

Build a Culture of Cyber Hygiene

Even with advanced technologies in place, humans remain the most common entry point for attackers. Risk teams should update training programs and promote a cyber-aware culture where every employee—right from clinicians to back-office staff—understands their role in protecting patient data.

Shift from Reactive to Proactive Risk Management

The new HIPAA updates clearly call for continuous risk assessment. Leaders should re-evaluate their current processes and adopt tools that enable real-time monitoring, automated alerts, and regular reviews of the risk landscape. Waiting for an incident before acting is no longer acceptable—or compliant.

Harmonize Compliance Across Frameworks

The updated rule also introduces a stronger alignment with other frameworks like NIST, ISO, and CISA guidelines. Organizations should look for ways to streamline controls across these standards to reduce redundancy, improve clarity, and ensure a unified compliance approach.

Prepare for Future Technology Integration

While AI-based cybersecurity tools are still emerging in healthcare, the promise they hold for early threat detection, real-time monitoring, and automated response is growing fast. Healthcare organizations should begin evaluating these tools now, ensuring they are implemented securely and responsibly when the right time approaches.

© 2025 Copyright MetricStream. All Rights Reserved.

Stay Ahead with MetricStream's Cyber GRC

Meeting evolving HIPAA requirements can be challenging for organizations dealing with outdated systems, constrained budgets, and increasing regulatory pressures. MetricStream's AI-first Cyber GRC solution simplifies and strengthens HIPAA compliance by automating IT and cyber risk identification, continuously testing and validating controls, enforcing compliance policies, and providing real-time insights into risk exposure across your cyber landscape. With agentic and generative AI at its core, Cyber GRC enables a proactive, streamlined approach to managing HIPAA compliance.

Centralized HIPAA Compliance Environment

Simplify and unify the management of HIPAA-specific risks, controls, policies, documentation, and audits within a centralized system of record, eliminating manual, spreadsheet-driven processes.

Integrated Regulatory Mapping and Harmonization

Map HIPAA requirements to broader frameworks such as NIST, ISO 27001, and CISA using the Unified Compliance Framework (UCF) and MetricStream GRC Library to ensure consistency and reduce duplication across regulatory mandates.

Automated and Scalable Compliance Workflows

Streamline repetitive processes — like policy reviews, risk assessments, training assignments, and control testing — through AI/ML-powered automation that scales with your organization's size and complexity.

Real-Time Monitoring and Reporting

Configurable dashboards and dynamic reports track HIPAA compliance metrics by business unit, risk rating, or information category, enabling timely decision-making and gap resolution.

Smarter Compliance Assessments and Scope Selection

Launch targeted assessments using intelligent scoping tools that consider risk scores and regulatory relevance to assign the right controls to the right owners, testers, and assessors.

Accelerated Issue Detection and Remediation

Detect and classify compliance issues based on criticality and business impact, and implement real-time remediation tracking with AI-driven recommendations for resolution paths.

Final Insight

The 2025 HIPAA Security Rule update represents a pivotal moment for the healthcare industry. As cyber threats grow more sophisticated and frequent, organizations must rethink how they protect sensitive patient information — not just to stay compliant, but to safeguard patient trust and safety.

By proactively planning for upcoming changes, educating teams, updating processes, and investing in the right tools, healthcare organizations can turn compliance into a strategic advantage.

With MetricStream, you're not just checking the box — you're building a foundation for resilience



metricstream

© 2025 Copyright MetricStream. All Rights Reserved.